보안 해커톤 기획 중간 정리

Oct 31, 2026 · @윤재영

한 줄 정의

ESS 배터리부터 관제센터 간 ICCP까지, 전력 데이터가 지나가는 **전 구간을 관통 감시**하고 **사이버 이상과 물리 이상을 교차 검증**해서 공격을 탐지하고 위조 위치까지 특정하는 플랫폼.

대상 범위

```
배터리 모듈 ─(CAN)─ BMS ─(Modbus TCP)─ ESS EMS ─(DNP3/IEC 104)─ 계통 EMS
─(ICCP)─ 타 관제센터
 └──────── 물리 이상탐지 구간 ────────┘
 └──────────────────── 프로토콜 IDS + 홉 간 일관성 검증 구간 ────────────────────┘
```

- **계통 EMS**: 전력회사 관제센터에서 송전망 전체를 관리하는 시스템
- **ESS EMS**: ESS 사이트 하나의 충방전을 관리하고 BMS·PCS에 지시하는 제어기
- **ICCP**: 관제센터 간 데이터 교환용 프로토콜. TLS를 적용한 Secure ICCP도 있지만, 현장에는 보안이 적용되지 않은 레거시가 많다는 점을 공략

핵심 기능

기능	내용
① 구간별 프로토콜 IDS	프로토콜별 화이트리스트·룰 기반 탐지 (비인가 명령, 이상 함수 코드, ICCP 비인가 association·Bilateral Table 위반 등)
② 홉 간 일관성 검증	같은 데이터(SOC 등)가 구간마다 같은 값으로 관측되는지 비교해 위조 구간 특정
③ 배터리 물리 이상탐지	배터리 근접 구간(CAN/BMS)에서 전압·전류·온도·SOC의 물리적 정합성 검증
④ SIEM 상관분석	①②③을 종합해 정상 / 장비 고장 / 정찰·실패한 공격 / 실제 공격으로 판정

사이버-물리 교차 판정

네트워크 이상	물리 이상	판정
없음	없음	정상
없음	있음	센서·장비 고장 또는 은밀한 위조 공격
있음	없음	정찰 단계 또는 실패한 공격
있음	있음	실제 공격 진행 중 (최고 위험도)

차별점

- **사이버 + 물리 교차 검증**으로 공격과 고장을 구분
- **홉 간 일관성 검증**으로 위조 구간을 특정 (단일 구간 IDS로는 불가능)
- 기존 SIEM 프로젝트와 달리 OT 프로토콜과 물리 도메인이 결합됨
- IPS가 아닌 IDS를 택한 근거: OT 환경에서는 오탐으로 인한 정상 제어 명령 차단이 곧 정전으로 이어짐

데모 공격 시나리오 후보

1. **BMS 값 위조로 과충전 은폐**: Modbus 구간에서 SOC·전압 조작 → ③과 ②가 탐지 (ESS 화재 이슈와 연결)
2. **ICCP 값 위조**: 타 센터로 넘어가는 데이터 조작 → ②가 탐지하고 위조 구간 특정
3. **ICCP 비인가 접근**: 허가되지 않은 association이나 제어 요청(Block 5) → ①이 탐지

기술 후보

구간	도구
CAN	python-can + 리눅스 가상 CAN(vcan)
Modbus	pymodbus
DNP3 / IEC 104	opendnp3, lib60870
ICCP	FreeTase2 또는 pyiec61850-ng (둘 다 실험 단계)
SIEM	기존 SIEM 프로젝트 구조 재활용

MVP 우선순위

1. **필수**: 핵심 데이터 몇 개가 전 구간을 관통하는 시뮬레이션 + ② 홉 간 일관성 검증 + SIEM 대시보드
2. **핵심 데모**: ③ 배터리 물리 이상탐지 + 시나리오 1·2
3. **여유 시**: ① 룰 확장, 시나리오 3, ML 기반 탐지

리스크

- **ICCP 라이브러리 불안정**: 초반에 연결 PoC부터 확인. 실패하면 해당 구간을 MMS 수준으로 대체하는 플랜 B
- **구간이 5개로 넓음**: 구간별 깊이보다 관통에 집중하고, 각 구간은 최소 기능만 구현

미정 사항

- [ ] 해커톤 기간과 팀 구성 (역할 분배, 일정)
- [ ] 메인 데모 시나리오 선정
- [ ] ③을 규칙·통계 기반으로만 할지, ML까지 넣을지